

TEST D'INTRUSION SUR L'ACTIVE DIRECTORY KERBEROASTING ET PASS-THE-HASH AVEC MIMIKATZ

Année académique: 2025-2026

**Elaboré par:
Abidi Mohamed Nadhir**



PLAN

01 Introduction

02 Kerberoasting

03 Pass-the-Hash avec Mimikatz

04 Conclusion

Active Directory (AD) est un service d'annuaire développé par Microsoft qui permet de centraliser la gestion des utilisateurs, des ordinateurs, des groupes et des ressources réseau dans un environnement **Windows**, tout en assurant l'authentification, l'autorisation et la sécurité.

02



Kerberoasting

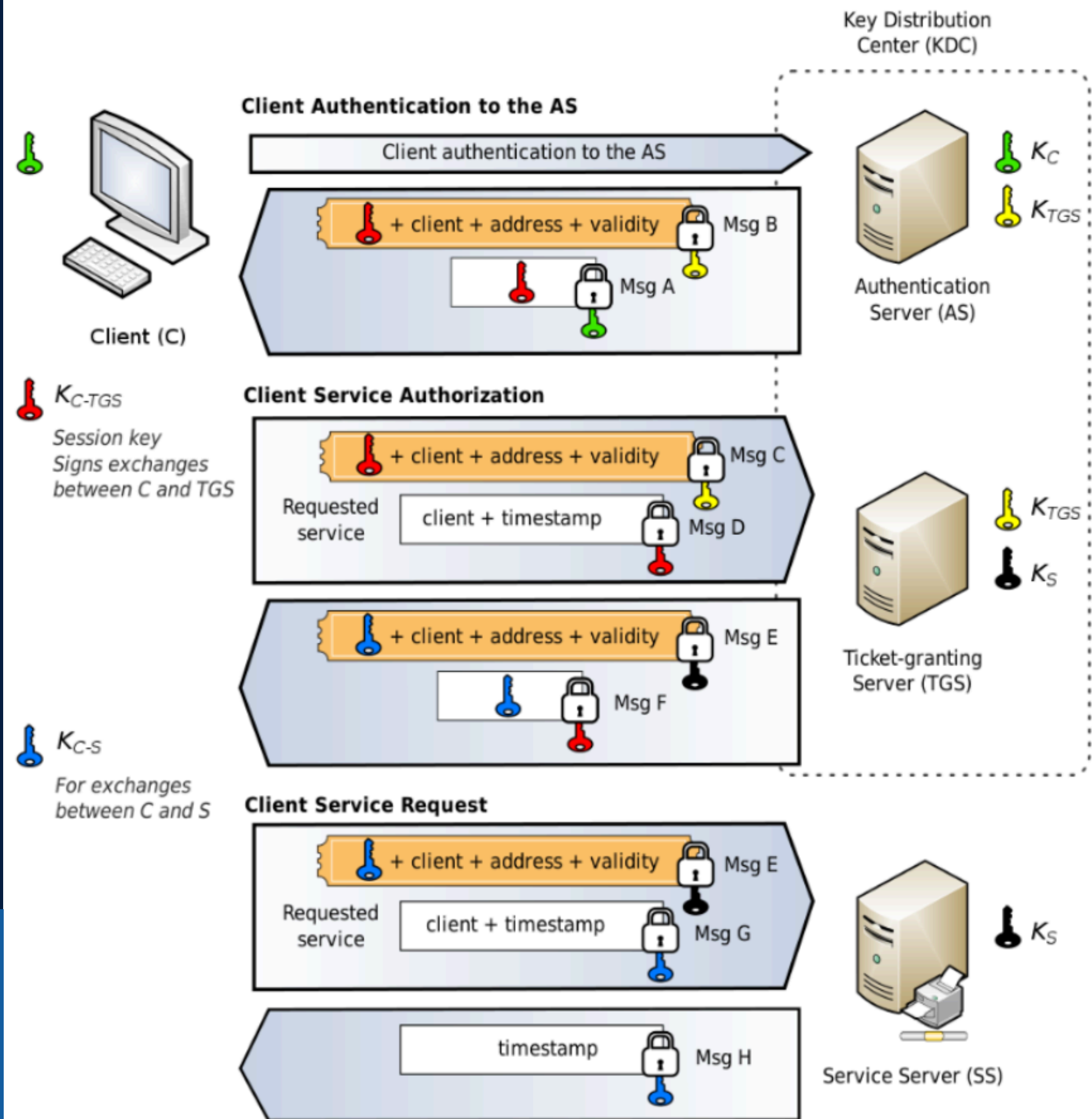
Qu'est-ce que le Kerberos ?

Kerberos est un protocole d'authentification réseau qui repose sur un mécanisme de clés secrètes (chiffrement symétrique) et l'utilisation de tickets, et non de mots de passe en clair, évitant ainsi le risque d'interception frauduleuse des mots de passe des utilisateurs.

Kerberos

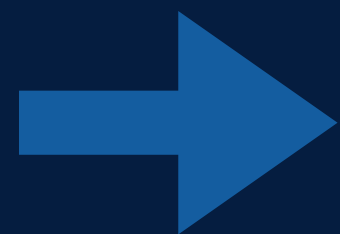
Fonctionnement de Kerberos

Le client C veut
accéder à
un service
proposé par le
serveur S:



Qu'est-ce que le Kerberoasting ?

Le Kerberoasting est une attaque qui cible le mécanisme Kerberos de Windows. L'attaquant récupère des tickets de service (TGS) et essaie de les cracker pour obtenir les mots de passe des comptes de service.

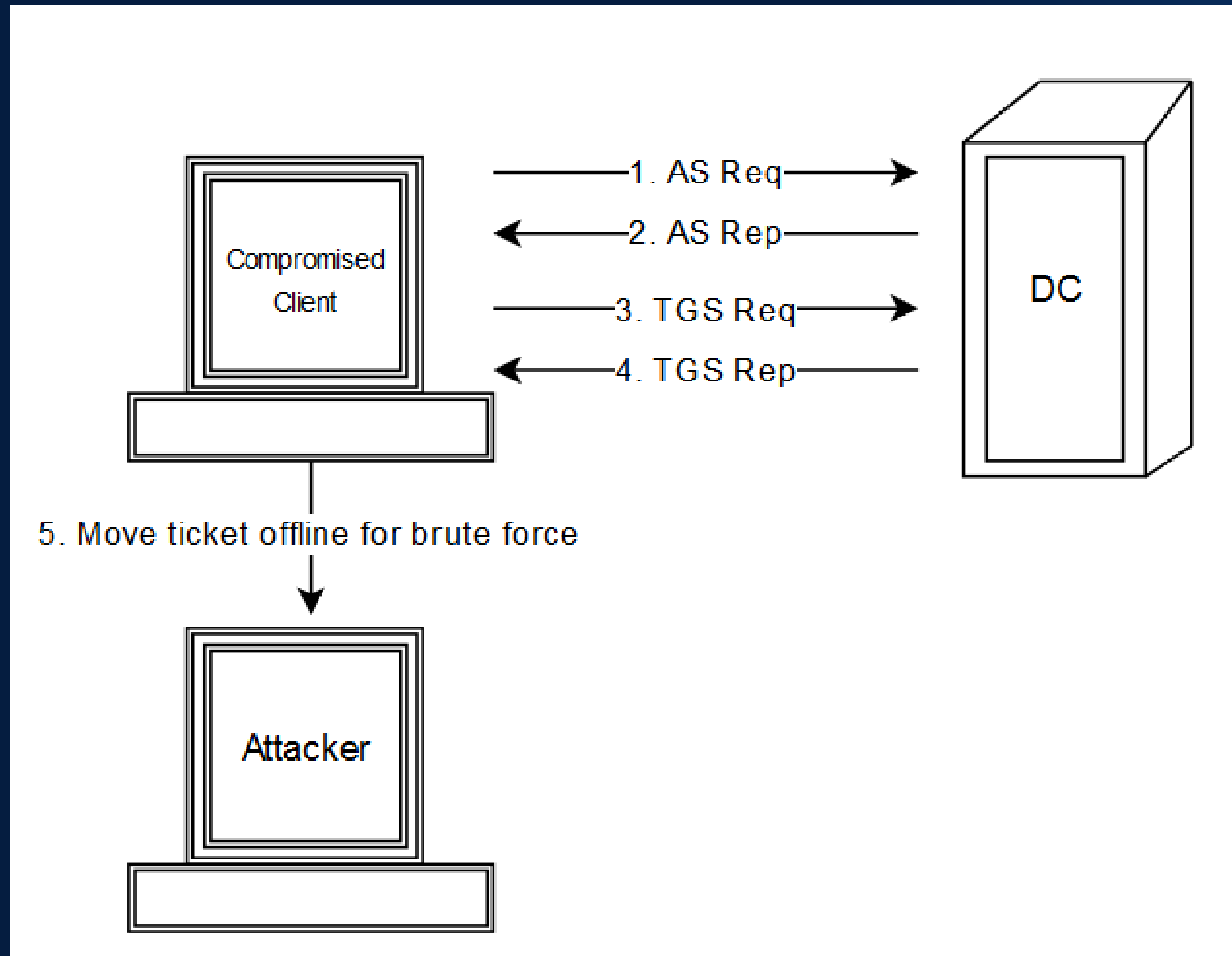


But de l'attaque : Obtenir des informations d'identification de service en utilisant des tickets Kerberos (TGS) obtenus via l'authentification.

Kerberoasting

Étapes de l'attaque

Le déroulement d'une attaque Kerberoasting est identique à celui d'un processus d'authentification Kerberos, à l'exception de l'étape 5, où l'attaquant extrait un ticket afin de procéder à un cassage hors ligne (offline cracking).



••• Étapes de l'attaque

Kerberoasting

Déroulement d'une attaque Kerberoasting standard :

- L'attaquant utilise un compte de domaine compromis pour demander un TGT au contrôleur de domaine via une Authentication Service Request (AS Req).
- Le contrôleur de domaine valide l'identité et renvoie le TGT par une Authentication Service Response (AS Rep).
- L'attaquant envoie ensuite le TGT dans une Ticket-Granting Service Request (TGS Req) afin d'obtenir un Service Ticket (ST).
- Si la requête aboutit, le contrôleur de domaine retourne le ST via une TGS Response (TGS Rep), lequel contient le mot de passe chiffré.
- Une fois le ST récupéré, l'attaquant peut le casser hors ligne à l'aide d'outils comme John the Ripper ou Hashcat.

Contre-mesures contre Kerberoasting

- **Utiliser AES** : Préférer l'authentification basée sur AES pour les tickets Kerberos.
- **Désactivation des comptes inutilisés** : Assurez-vous que les comptes de service ne sont pas obsolètes
- **Surveillance et audit** : Configurer des audits de Kerberos dans l'Active Directory pour détecter les tentatives d'attaque.

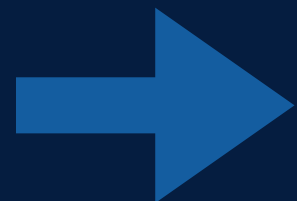
03



Pass-the-Hash avec Mimikatz

Qu'est-ce que le Pass-the-Hash ?

Le NTLM (NT LAN Manager) est un protocole d'authentification utilisé par les systèmes Windows pour vérifier l'identité d'un utilisateur dans un réseau. Lorsqu'un utilisateur entre son mot de passe, ce mot de passe n'est pas directement stocké dans la base de données. Au lieu de cela, Windows crée un hash du mot de passe qui ne peut pas être reconvertie en clair.



But de l'attaque : Utiliser le hash NTLM volé pour accéder à des systèmes distants ou obtenir des privilèges élevés.

Pré-requis de l'attaque (Pass-the-Hash)

- **Obtenir un hash NTLM valide** : L'attaquant doit obtenir un hash NTLM valide, généralement via l'extraction de mots de passe stockés dans la mémoire ou les fichiers.
- **Outil utilisé** : Mimikatz est un outil populaire pour extraire et utiliser les hashes NTLM.

Étapes de l'attaque

- **Étape 1** : L'attaquant récupère un hash NTLM d'un utilisateur cible.
- **Étape 2** : Utilisation du hash NTLM pour se connecter à une machine distante (sans besoin du mot de passe).
- **Étape 3** : Escalade de privilèges sur le domaine, si l'accès est obtenu à un compte avec des privilèges élevés (ex. administrateur).

Contre-mesures contre Pass-the-Hash

- **Limiter les privilèges** : Appliquer le principe du moindre privilège pour réduire les impacts d'une attaque réussie.
- **Utiliser Kerberos** : Privilégier Kerberos comme méthode d'authentification (éliminer l'utilisation de NTLM).
- **LAPS (Local Administrator Password Solution)** : Utiliser LAPS pour gérer les mots de passe des administrateurs locaux.
- **Réduire la durée de vie des sessions** : Utiliser des délais courts pour les sessions d'administrateurs.

04

CONCLUSION



L'Active Directory est essentiel pour la gestion des ressources réseau, mais sa centralisation le rend vulnérable à plusieurs attaques. Il est crucial de renforcer sa sécurité pour protéger les données et prévenir les intrusions.

**MERCI DE
VOTRE
ATTENTION!**